```
        tokenController.requireScope("POST",
"add_member"));    #C
before("/spaces/:spaceId/members",
        userController.requirePermission("POST", "rwd"));
post("/spaces/:spaceId/members", spaceController::addMember);

before("/spaces/*/messages/*",    #C
        tokenController.requireScope("DELETE",
"delete_message"));    #C
before("/spaces/:spaceId/messages/*",
        userController.requirePermission("DELETE", "d"));
delete("/spaces/:spaceId/messages/:msgId",
    moderatorController::deletePost);
```

#A Ensure that obtaining a scoped token itself requires a restricted scope.
#B Revoking a token should not require any scope.
#C Add scope requirements to each operation exposed by the API.

7.1.2 The difference between scopes and permissions

At first glance, it may seem that scopes and permissions are very similar, but there is a distinction in what they are used for, as shown in figure 7.2. Typically, an API is owned and operated by a central authority such as a company or an organization. Who can access the API and what they are allowed to do is controlled entirely by the central authority. This is an example of *mandatory access control*, because the users have no control over their own permissions or those of other users. On the other hand, when a user delegates some of their access to a third-party app or